

DATABASE SYSTEMS

CHAP. 9: Database Security and Authorization

Database Security

- Database Security
 - Protection of the data against accidental or intentional loss, destruction, or misuse
- Examples
 - Accidental data loss
 - Imagine a company that loses a formulae to a new product at the advantage of a competitor.
 - Intentional data loss
 - Imagine an employee who gives away data of an insurance company.

Database Security (Cont.)

- Destruction of data
 - Imagine students who delete the text of their research project at the moment of printing.
- Misuse of data
 - Imagine a hacker who enters the records of a bank and modifies balances on accounts of its customers as he wishes.

Database Authorization

- Database Authorization
 - Controls what a user account has access to in the database.
- Example
 - If you do not want data entry users to alter the salary column of the employees table, you will not grant them the right to alter data.
 - If you do not want cashiers to see the balances of customer accounts, you deny them the right to read balances.

Threats to Data Security

- Accidental losses
- Theft and fraud.
- Improper data access
- Loss of data integrity
- Loss of availability (through, e.g. Sabotage)
- Threat

Accidental losses

- Hardware faults or failure
- Software or media faults
- Virus infection or malicious hacking
- Power failure
- Human errors by changing or deleting files

Theft and fraud

- Identity theft refers to the preparatory stage of acquiring and collecting someone else's personal information for criminal purposes.
- Identity fraud is the actual deceptive use of the identity information of another person in connection with various frauds.

Improper data access

- Loss of privacy (personal data)
- Loss of secrecy
- Loss of confidentiality
(corporate data)

Loss of data integrity

- Can lead to companies and individuals losing very important pieces of information.

Loss of availability (through, e.g. Sabotage)

- The database is unusable

Threat

- Any situation or event, whether intentional or unintentional, that will adversely affect a system and consequently an organization.

Countermeasures

- Authorization
- Authentication
- View
- Backup
- Journalizing

Countermeasures(Cont.)

- Integrity
- Encryption
- Raid (redundant array of independent disks) technology
- User-defined procedures
- Checkpointing

Authorization

- The granting of a right or privilege, which enables a subject to legitimately have access to a system or a system's object.

Authentication

- A mechanism that determines whether users are who they claim to be.

View

- Produced upon request by a particular user, at the time of request.

Backup

- Process of periodically taking a copy of the database and log file (and possibly programs) to offline storage media.

Journalizing

- Process of keeping and maintaining a log file (or journal) of all changes made to database to enable effective recovery in event of failure.

Integrity

- Prevents data from becoming invalid.

Encryption

- The encoding of the data by a special algorithm that renders the data unreadable by any program without the decryption key.

Raid

- RAID , "redundant array of independent disks" , uses multiple disks in order to provide fault tolerance, to improve overall performance, and to increase storage capacity in a system.

User-defined procedures

- DBMSs provide capabilities for *user-defined procedures* to customize the authorization process

Checkpointing

- DBMS periodically refuses to accept new transactions
- Database and transaction logs are synchronized

Database Failure Responses

- Aborted transactions
- Incorrect data
- System failure (database intact)
- Database destruction

Aborted transactions

- **Preferred recovery**
 - rollback
- **Alternative**
 - rollforward to state just prior to abort

Incorrect data

- **Preferred recovery**

- Rollback

- **Alternative 1**

- Re-run transactions not including inaccurate data updates

- **Alternative 2**

- Compensating transactions

System failure

- **Preferred recovery**
 - Switch to duplicate database
- **Alternative 1**
 - Rollback
- **Alternative 2**
 - Restart from checkpoint

Database destruction

- **Preferred recovery**
 - Switch to duplicate database
- **Alternative 1**
 - Rollforward
- **Alternative 2**
 - Reprocess transactions